



Speaker Notes

Security Attacks and Security Services

Lesson 3: Types of Attacks

Lesson 9: Attacks, Services and the Security Model

How to use these notes

- There is **one note for each of the 48 slides**, in the same order as module2.pdf. A small picture of the slide sits beside each note.
- The notes are written **from teacher to students**: speak them as they are, or use them as a guide in your own words.
- Each note is about **100–111 words**, which takes roughly **45–50 seconds** at a steady classroom pace of about 135 words per minute. The estimate for each slide is shown in its title bar.
- Phrases such as “look at the diagram” tell you when to point at the slide.

Slides	48
Total words	4,968
Estimated talking time	about 37 minutes (without pauses or questions)
Lesson 3	slides 3–28
Lesson 9	slides 29–48

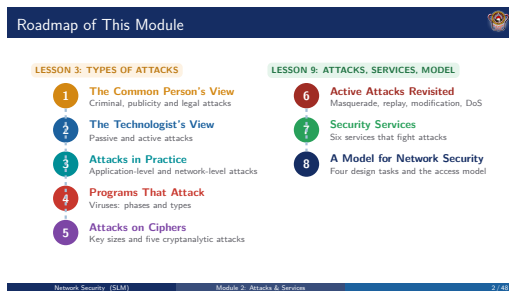


Slide 1 | Title: Security Attacks and Security Services (about 49 seconds)



Good morning, everyone. Welcome to Module 2 of our Network Security course: Security Attacks and Security Services. In Module 1 we met the basic vocabulary of security. Today we go deeper. Look at the picture on the right: a shield protecting a lock, with red arrows striking at it from outside. That is exactly our story today. The red arrows are attacks, and the shield is made of security services. This module combines Lesson 3, Types of Attacks, and Lesson 9, which covers attacks, services and a model for network security. By the end, you should be able to name the attacks and explain how we defend against each one.

Slide 2 | Roadmap of This Module (about 47 seconds)



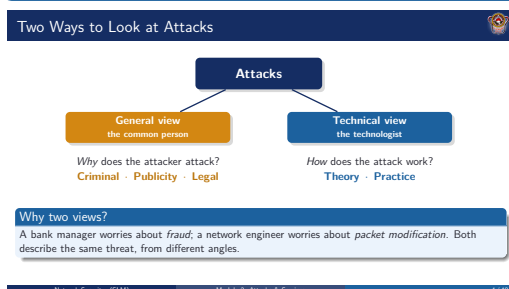
Here is our roadmap for today. The left column comes from Lesson 3. We start with the common person's view of attacks, then the technologist's view, then see how attacks happen in practice. Next, we study programs that attack, mainly viruses, and then attacks on ciphers, including key sizes. The right column comes from Lesson 9. We revisit active attacks in more detail, then learn the six security services that fight attacks, and finally a model for network security that ties everything together. Notice how the module moves from the problem, which is attacks, to the solution, which is services. Keep this flow in mind throughout.

Slide 3 | Lesson 3: Types of Attacks (about 49 seconds)



We now begin Lesson 3, Types of Attacks. Let me ask you a question first. If someone attacks a computer system, why do they do it, and how do they do it? These two questions are the backbone of this lesson. We will first look at attacks the way an ordinary person sees them, through the reason behind the attack. Then we will look at them the way an engineer sees them, through how the attack actually works. Later, we will study viruses and the different attacks on encrypted messages. This lesson has many examples from real life, so try to connect each one with news stories you may have heard.

Slide 4 | Two Ways to Look at Attacks (about 48 seconds)

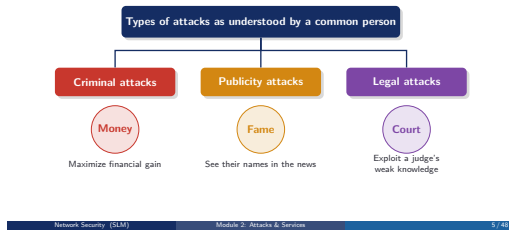


Look at the tree on the slide. We classify attacks from two points of view. On the left is the general view, the common person's view. It asks why the attacker attacks. From this angle we get three categories: criminal attacks, publicity attacks and legal attacks. On the right is the technical view, the technologist's view. It asks how the attack works. From this angle we talk about theoretical concepts and practical approaches. Why do we need both views? The blue box explains: a bank manager worries about fraud, while a network engineer worries about packets being modified. Both are describing the same threat, just from different angles.



Slide 5 | The General View: Three Categories (about 46 seconds)

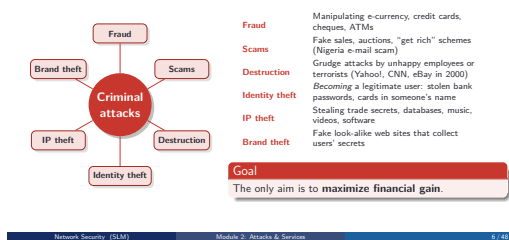
The General View: Three Categories



From the common person's point of view, there are three categories of attack. First, criminal attacks, shown in red. The motive here is money: the attacker wants to maximise financial gain. Second, publicity attacks, shown in orange. The motive is fame: the attacker wants to see their name in the news. Third, legal attacks, shown in purple. The motive is to win in court, by exploiting the judge's weak knowledge of technology. Please remember these three words, money, fame and court, because they make this classification very easy to recall. The next three slides take each category one at a time, with examples.

Slide 6 | Criminal Attacks (about 46 seconds)

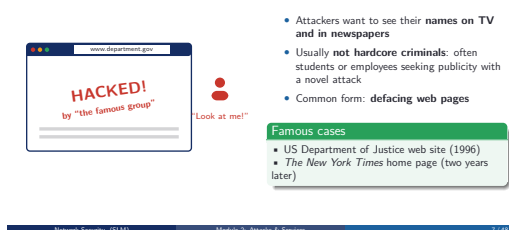
Criminal Attacks



Criminal attacks are the simplest to understand, because the only aim is financial gain. The diagram shows six types. Fraud means manipulating electronic currency, credit cards, cheques or ATMs. Scams are fake sales, auctions or get-rich-quick schemes, like the famous Nigerian e-mail scam. Destruction comes from a grudge, for example unhappy employees or terrorists; in 2000, sites like Yahoo, CNN and eBay were attacked. Identity theft means the attacker becomes the legitimate user, using stolen bank passwords. Intellectual property theft means stealing trade secrets, software or music. Brand theft means creating fake look-alike websites to collect users' secrets. All six share one goal: money.

Slide 7 | Publicity Attacks (about 46 seconds)

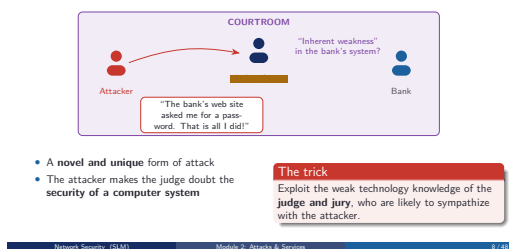
Publicity Attacks



Publicity attacks happen because the attackers want their names to appear on television and in newspapers. Look at the browser window on the slide: a government web page has been replaced with the word HACKED. Defacing web pages like this is the most common form of publicity attack. Interestingly, history shows that these attackers are usually not hardcore criminals. They are often students or employees in large organizations who want attention through a novel attack. Two famous cases are listed in the green box: the US Department of Justice website in 1996, and the New York Times home page about two years later.

Slide 8 | Legal Attacks (about 47 seconds)

Legal Attacks

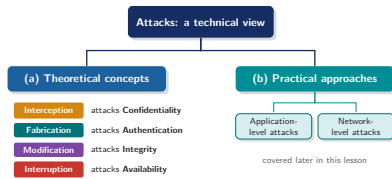


Legal attacks are quite novel and unique. Look at the courtroom scene. The attacker deliberately makes the judge and jury doubt the security of a computer system. For example, an attacker might sue a bank over an online transaction she never really wanted to perform. In court, she says innocently, as shown in the speech bubble: the bank's website asked me for a password, and that is all I did. The judge may suspect an inherent weakness in the bank's system. The trick, as the red box explains, is to exploit the weak technology knowledge of the judge and jury, who may sympathize with the attacker.



Slide 9 | The Technical View (about 46 seconds)

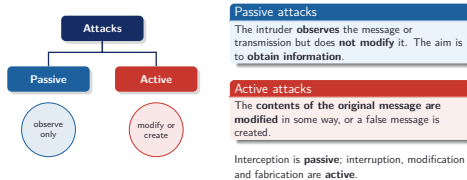
The Technical View



Now let us switch to the technologist's view. The tree shows two branches. On the left are theoretical concepts. These are the four attacks you already know from Module 1. Interception attacks confidentiality. Fabrication attacks authentication. Modification attacks integrity. And interruption attacks availability. Please learn these four pairs well; they come up in almost every examination. On the right are practical approaches, which split into application-level attacks and network-level attacks. We will study those later in this lesson. For now, remember that the technical view is all about how an attack is carried out, not why. Keep that difference clear in your mind.

Slide 10 | Passive and Active Attacks (about 45 seconds)

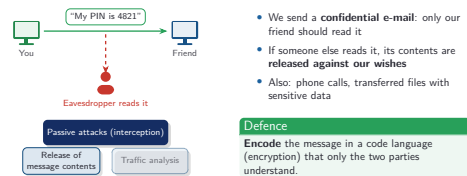
Passive and Active Attacks



The four theoretical attacks are grouped into two types, as the tree shows. Passive attacks are those where the intruder only observes the message or transmission, but does not modify it. The aim is simply to obtain information, so think of the words observe only. Active attacks are those where the contents of the original message are modified in some way, or a false message is created. Think of the words modify or create. A simple way to remember: interception is passive, because the attacker only listens. Interruption, modification and fabrication are all active, because the attacker changes something in the system.

Slide 11 | Passive Attack 1: Release of Message Contents (about 48 seconds)

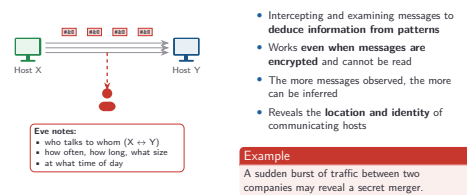
Passive Attack 1: Release of Message Contents



Passive attacks are further divided into two kinds: release of message contents, and traffic analysis. Let us take the first. Look at the diagram. You send a confidential e-mail to your friend saying, my PIN is 4821. Only your friend should read it. But an eavesdropper silently reads it on the way. The contents have been released against your wishes. The same can happen to phone calls and transferred files. What is the defence? As the green box says, we encode the message in a code language that only the two parties understand. In other words, we use encryption. Even if Eve captures it, she cannot read it.

Slide 12 | Passive Attack 2: Traffic Analysis (about 45 seconds)

Passive Attack 2: Traffic Analysis

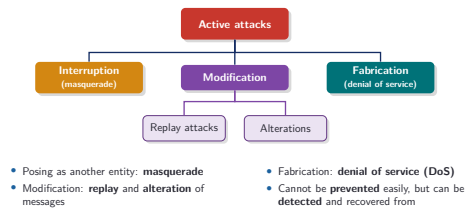


The second passive attack is more subtle: traffic analysis. Suppose X and Y encrypt all their messages, so Eve cannot read them. Is Eve helpless? Not at all. Look at her notes on the slide. She records who is talking to whom, how often, how long, how big the messages are, and at what time of day. From these patterns she can deduce a lot. The more messages she observes, the more she can infer. For example, as the red box says, a sudden burst of traffic between two companies may reveal a secret merger, even though no message was ever decrypted.



Slide 13 | Classification of Active Attacks (about 44 seconds)

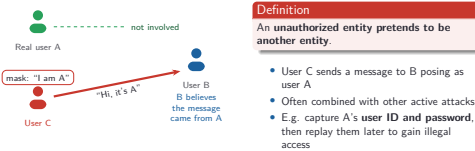
Classification of Active Attacks



Now let us classify the active attacks, using the tree from your study material. Active attacks are grouped into interruption, modification and fabrication. Under interruption we have masquerade, where the attacker poses as another entity. Modification is divided into two: replay attacks and alterations. Fabrication causes denial of service, or DoS. Remember one important point from the bottom right of the slide: active attacks cannot be prevented easily, but with some effort they can be detected, and we can recover from them. In the next four slides, we will look at each of these active attacks with a simple example.

Slide 14 | Active Attack: Masquerade (about 45 seconds)

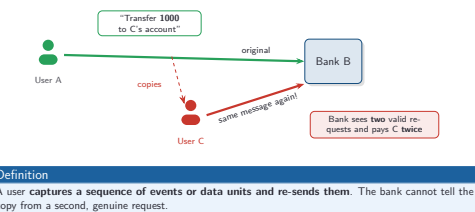
Active Attack: Masquerade



A masquerade attack is caused when an unauthorized entity pretends to be another entity. Look at the diagram. User C is wearing a mask that says, I am A, and sends a message to user B. B believes the message came from A, while the real user A is not involved at all. In masquerade attacks, usually other forms of active attacks are also included. For example, the attacker may first capture A's user ID and password, which is called the authentication sequence. Later, those captured details are replayed to gain illegal access to the system, as if C were A.

Slide 15 | Active Attack: Replay (about 46 seconds)

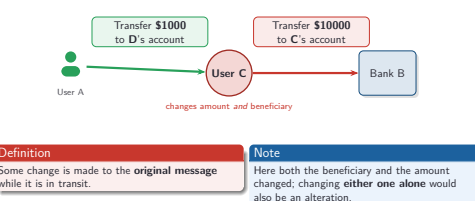
Active Attack: Replay



In a replay attack, a user captures a sequence of events or data units, and re-sends them. Here is the example from your study material. User A wants to transfer an amount to C's bank account, so A sends an electronic message to bank B. User C, the attacker, captures a copy of that message. Later, C sends exactly the same message to the bank again. Look at the red box: the bank sees two valid requests, and has no way of knowing that the second one is a copy. So C gets paid twice, once authorized, and once through the replay attack.

Slide 16 | Active Attack: Alteration of Messages (about 45 seconds)

Active Attack: Alteration of Messages

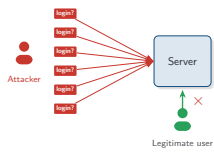


Alteration of messages involves some change to the original message while it is in transit. Look at the example. User A sends a message to the bank saying, transfer one thousand dollars to D's account. User C, sitting in the middle, captures it and changes it to say, transfer ten thousand dollars to C's account. The bank, of course, has no idea. Notice that in this example, both the beneficiary and the amount have changed. But as the blue box notes, changing either one of them alone, only the amount or only the name, would also count as an alteration attack.



Slide 17 | Active Attack: Denial of Service (DoS) (about 45 seconds)

Active Attack: Denial of Service (DoS)



Definition

An attempt to **prevent legitimate users** from accessing services they are eligible for.

Example

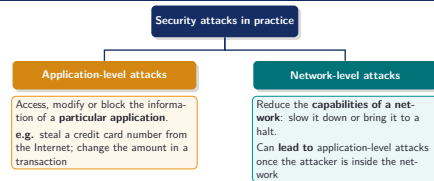
- Send too many login requests with random user IDs in quick succession
- The network is **flooded**
- Legitimate users are denied the facilities

Threatens: **availability**

Denial of service attacks try to prevent legitimate users from accessing services they are eligible for. Look at the diagram. The attacker on the left sends a flood of login requests to the server, using random user IDs, one after another in quick succession. The server is so busy handling these fake requests that when a genuine user tries to log in, they are rejected, as shown by the red cross. The network is flooded, and legitimate users are denied its facilities. Which security goal does DoS threaten? Availability. Whenever a service becomes unusable for real users, think of denial of service.

Slide 18 | The Practical Side of Attacks (about 47 seconds)

The Practical Side of Attacks



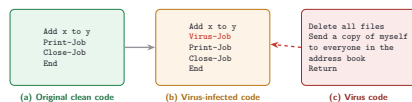
Key sentence

Security attacks can happen at the **application level** or at the **network level**, using many mechanisms.

Now let us look at attacks in practice. In real life, attacks fall into two broad categories. Application-level attacks, on the left, try to access, modify or block the information of a particular application. Examples are stealing someone's credit card number from the Internet, or changing the amount in a transaction. Network-level attacks, on the right, aim to reduce the capabilities of a network, slowing it down or bringing it to a complete halt. Note an important point: a network-level attack can lead to application-level attacks, because once the attacker gets inside the network, they can reach sensitive information. Remember the key sentence at the bottom.

Slide 19 | Programs That Attack: The Virus (about 46 seconds)

Programs That Attack: The Virus



Definition

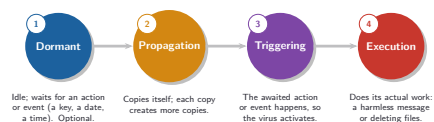
A computer program that **attaches itself to another legitimate program** and causes damage to the computer system or network.

- Runs whenever the host program runs
- Can infect other programs on the same computer or network
- Can be triggered by events (e.g. 12 PM every day)

Some programs are written specifically to attack computer systems. The best known is the virus. Look at the three boxes. Box (a) is the original clean code: add x to y, print, close, end. Box (c) is the virus code: delete all files, send a copy of myself to everyone in the address book, return. Box (b) shows what happens after infection: the virus job is inserted into the legitimate program. Now, whenever the program runs, the virus runs too. So, a virus is a computer program that attaches itself to another legitimate program and causes damage to the computer system or network.

Slide 20 | The Four Phases of a Virus (about 46 seconds)

The Four Phases of a Virus



Good news

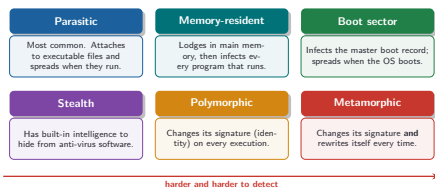
Usually the damage can be repaired, provided the organization keeps **good backup and recovery** procedures.

During its lifetime, a virus goes through four phases. Follow the circles from left to right. First is the dormant phase, where the virus is idle, waiting for some action or event such as a key press, a date or a time. This phase is optional. Second is the propagation phase, where the virus copies itself, and each copy creates more copies. Third is the triggering phase: the awaited event happens, and the virus activates. Fourth is the execution phase, where the virus does its actual work, which could be a harmless message or deleting files. Good backups help us recover from the damage.



Slide 21 | Types of Viruses (about 45 seconds)

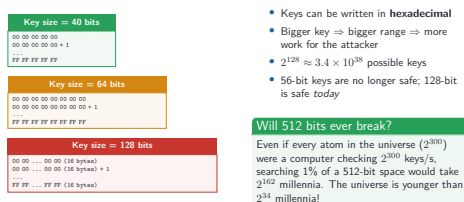
Types of Viruses



Viruses are classified into six types. Parasitic viruses are the most common; they attach to executable files and spread when those files run. Memory-resident viruses first lodge in main memory, then infect every program that runs. Boot sector viruses infect the master boot record and spread when the operating system boots. Stealth viruses have built-in intelligence to hide from anti-virus software. Polymorphic viruses change their signature, or identity, on every execution. Metamorphic viruses change their signature and also rewrite themselves completely every time. Look at the red arrow at the bottom: as we move across, viruses become harder and harder to detect.

Slide 22 | Key Sizes and Ranges (about 46 seconds)

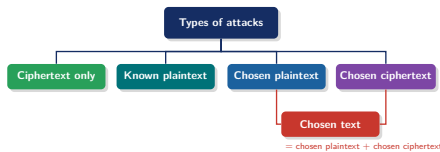
Key Sizes and Ranges



Let us now talk about keys. On the left, you can see key ranges written in hexadecimal for forty, sixty-four and one hundred and twenty-eight bit keys. Each range starts at all zeros and ends at all F's. The bigger the key, the bigger the range, and the more work for an attacker. A one hundred and twenty-eight bit key gives about three point four times ten to the power thirty-eight possible keys. Fifty-six-bit keys are no longer safe, while one hundred and twenty-eight bits is safe today. And the green box explains why five hundred and twelve-bit keys will practically always be safe.

Slide 23 | Possible Types of Attacks on a Cipher (about 44 seconds)

Possible Types of Attacks on a Cipher



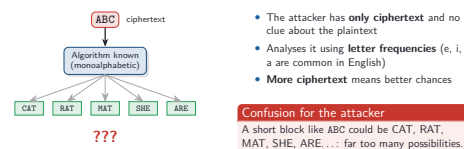
The setting

The sender encrypts a plaintext message into ciphertext. The attacker's goal is to find the **plaintext** or, better, the **key**. What the attacker already knows decides which of these **five** attacks is possible.

When a sender encrypts a plaintext message into ciphertext, an attacker can try five types of attack, shown in this tree. They are: ciphertext only, known plaintext, chosen plaintext, chosen ciphertext, and chosen text. Notice at the bottom that chosen text is simply a combination of chosen plaintext and chosen ciphertext. The attacker's goal is to find the plaintext, or even better, the key, because the key unlocks every message. Remember the main idea in the blue box: what the attacker already knows decides which of these five attacks is possible. Let us now look at each attack in turn.

Slide 24 | Ciphertext-Only Attack (about 46 seconds)

Ciphertext-Only Attack

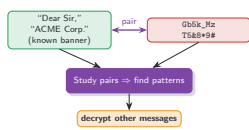


In a ciphertext-only attack, the attacker has no clue about the plaintext. She has only some or all of the ciphertext. She can analyse it at leisure, for example using letter frequencies, since letters like e, i and a are very common in English. More ciphertext gives better chances. But look at the diagram for a problem. Suppose the ciphertext is just ABC, and the attacker knows a monoalphabetic cipher was used. ABC could be CAT, RAT, MAT, SHE, ARE, and many more. There are far too many possibilities. So a very short ciphertext creates confusion for the attacker, which works in our favour.



Slide 25 | Known-Plaintext Attack (about 45 seconds)

Known-Plaintext Attack



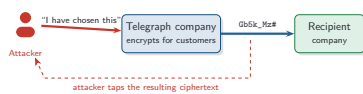
- The attacker knows some plaintext-ciphertext pairs
- Uses them to find **more** pairs and more plaintext
- Examples: company banners, file headers, standard greetings

How does the attacker get plaintext?
Old plaintext may become **outdated** and **public**, or be leaked inadvertently.

In a known-plaintext attack, the attacker knows some pairs of plaintext and the matching ciphertext. Look at the diagram: a known banner such as Dear Sir or a company name, paired with its encrypted form. By studying these pairs, the attacker looks for patterns, and uses them to find more pairs and decrypt other messages. Where does known plaintext come from? Company banners, file headers and standard greetings appear in almost every document. Also, as the blue box says, old plaintext may become outdated and public over time, or it may be leaked by accident. Either way, it helps the attacker.

Slide 26 | Chosen-Plaintext Attack: The Telegraph Story (about 45 seconds)

Chosen-Plaintext Attack: The Telegraph Story



Definition

The attacker selects a **plaintext block** and obtains its ciphertext, deliberately picking patterns that reveal more about the key.

- A telegraph company encrypts people's messages for them
- The attacker simply **pays** to send a chosen text
- Now they own a matching plaintext-ciphertext pair

In a chosen-plaintext attack, the attacker selects a plaintext block and obtains its ciphertext, deliberately picking patterns that reveal more about the key. How is this possible in real life? Here is the story from your study material. A telegraph company offers a paid service: it encrypts people's messages and sends them on. The attacker simply pays the company to send a message she has chosen herself. Then, as the dashed line shows, she taps the line and captures the resulting ciphertext. Now she owns a matching pair of plaintext she chose and its ciphertext, which helps her attack the key.

Slide 27 | Chosen-Ciphertext and Chosen-Text Attacks (about 48 seconds)

Chosen-Ciphertext and Chosen-Text Attacks



Chosen ciphertext

The attacker knows the ciphertext to be decrypted, the **algorithm**, and the corresponding plaintext block. The job: **discover the key**. Not very common.

Chosen text

Essentially a **combination** of the chosen-plaintext and chosen-ciphertext attacks.

In a chosen-ciphertext attack, shown on the left, the attacker knows the ciphertext to be decrypted, the encryption algorithm used, and the corresponding plaintext block. The attacker's job is to discover the key that was used for encryption. Your study material notes that this type of attack is not very common. On the right is the chosen-text attack. It is not really a new idea: it is essentially a combination of the chosen-plaintext attack and the chosen-ciphertext attack, as the diagram shows. So if you understand the previous two attacks, you already understand chosen text. Now let us put all five attacks side by side in one table.

Slide 28 | Summary of Attacks on Ciphers (about 47 seconds)

Summary of Attacks on Ciphers

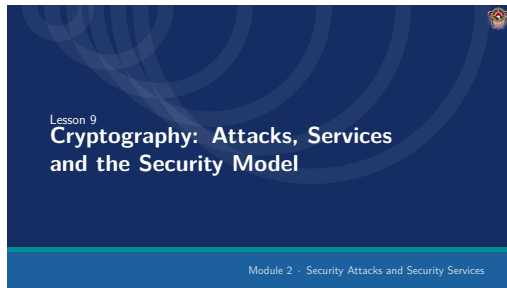
Attack	Things known to the attacker	Things the attacker wants
Ciphertext only	Ciphertext of several messages (same key); algorithm	Plaintext of those messages; the key
Known plaintext	Ciphertext of several messages; some matching plaintext; algorithm	Algorithm to decrypt; the key
Chosen plaintext	Ciphertext and plaintext; chooses the plaintext to encrypt	The key; decryption of other ciphertext
Chosen ciphertext	Ciphertext of messages to be decrypted; matching plaintext	The key used for encryption
Chosen text	Some of the above	Some of the above

Reading down the table, the attacker **knows more**, so the attack becomes **more powerful**.

This table summarises all five attacks, and it is an excellent table to copy into your notebook. For each attack, the middle column shows what the attacker already knows, and the right column shows what the attacker wants to find out. For ciphertext only, the attacker knows the ciphertext and the algorithm, and wants the plaintext and the key. For known plaintext, the attacker also knows some matching plaintext. Chosen plaintext lets the attacker choose what to encrypt. And so on down the table. The key observation is at the bottom: as we read down, the attacker knows more, so the attack becomes more powerful.

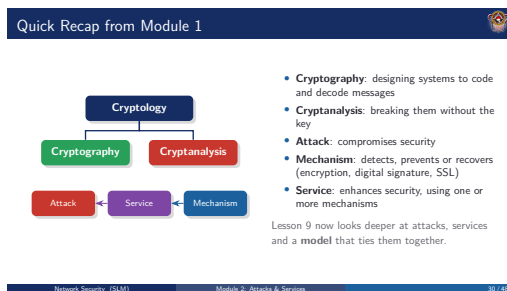


Slide 29 | Lesson 9: Cryptography: Attacks, Services and the Security Model (about 44 seconds)



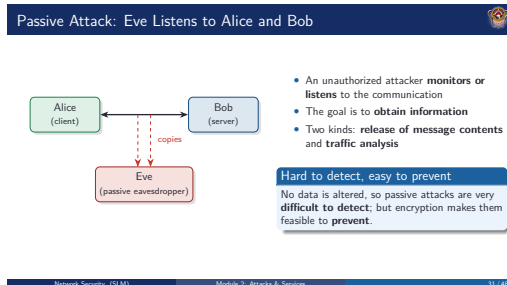
We now move to Lesson 9. In your study material it is titled Cryptography, but its heart is attacks, security services and a model for network security. Some of the ideas will feel familiar, because they build on Lesson 3. That is good: repetition with more depth is how we master a subject. In this lesson, we will look again at passive and active attacks using standard names. Then we will study the six security services one by one. Finally, we will learn a general model for network security and a model for protecting an information system from unwanted access.

Slide 30 | Quick Recap from Module 1 (about 45 seconds)



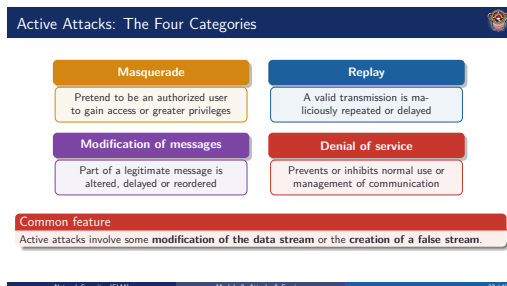
Before we go further, a quick recap from Module 1. Look at the tree on the left. Cryptology has two branches: cryptography, which is designing systems to code and decode messages, and cryptanalysis, which is breaking those systems without the key. Below that is the chain of three aspects. An attack compromises security. A mechanism, such as encryption, digital signatures or SSL, detects, prevents or recovers from attacks. And a service enhances security by using one or more mechanisms. If you are comfortable with these five terms, you are ready for Lesson 9. If not, please revise Module 1 this evening.

Slide 31 | Passive Attack: Eve Listens to Alice and Bob (about 45 seconds)



This diagram is a classic in security books. Alice, the client, is talking to Bob, the server. Eve, the passive eavesdropper, quietly copies everything. The name Eve comes from eavesdropper, which makes it easy to remember. In a passive attack, an unauthorized attacker monitors or listens to the communication, and the goal is only to obtain information. The two kinds are release of message contents and traffic analysis, as we saw in Lesson 3. Remember the important point in the blue box: passive attacks are very difficult to detect because no data is altered, but they are feasible to prevent using encryption.

Slide 32 | Active Attacks: The Four Categories (about 44 seconds)



In Lesson 9, active attacks are divided into four standard categories. Masquerade, in orange, is pretending to be an authorized user to gain access or greater privileges. Replay, in blue, is when a valid data transmission is maliciously repeated or delayed. Modification of messages, in purple, means part of a legitimate message is altered, delayed or reordered. And denial of service, in red, prevents or inhibits the normal use or management of communication facilities. The common feature, in the red box, is that all active attacks involve some modification of the data stream, or the creation of a false stream.

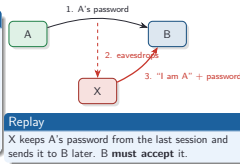


Slide 33 | Masquerade and Replay in Detail (about 46 seconds)

Masquerade and Replay in Detail

Masquerade

- Uses **stolen logon IDs and passwords**, security gaps, or bypasses authentication
- May come from **inside** the organization or from outside
- **Weak authentication** is the easiest entry point
- Once in, the attacker may modify or delete data and change network configuration



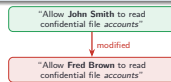
Let us look at masquerade and replay in more detail. A masquerade may use stolen logon IDs and passwords, find security gaps in programs, or bypass authentication altogether. It may come from inside the organization or from outside. Weak authentication is the easiest point of entry. Once inside, the attacker may modify or delete data and change network configuration. Now look at the replay diagram on the right. A sends its password to B. Meanwhile, X eavesdrops and keeps the password. Later, X connects to B, says, I am A, and sends the old password. B has no choice but to accept it.

Slide 34 | Modification and Denial of Service in Detail (about 46 seconds)

Modification and Denial of Service in Detail

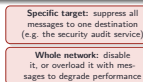
Modification of messages

A message is altered, **delayed** or **reordered** to produce an unauthorized effect.



Denial of service

Prevents or inhibits the normal use or management of communication facilities.



Modification of messages means a part of a legitimate message is altered, delayed or reordered, to produce an unauthorized effect. Look at the example on the left. The original message says, allow John Smith to read the confidential file accounts. It is modified to say, allow Fred Brown to read the confidential file accounts. A tiny change, but a big security breach. On the right is denial of service. It may have a specific target, for example suppressing all messages going to the security audit service. Or it may attack the whole network, disabling it or overloading it with messages to degrade performance.

Slide 35 | Passive vs. Active: What Should We Do? (about 48 seconds)

Passive vs. Active: What Should We Do?

Passive attacks

Very difficult

Feasible

Prevention (encryption)

No data is altered

Active attacks

Detect?

Prevent?

Strategy

Why?

Possible

Very difficult

Detection and recovery

Too many physical, software, network weaknesses

Bonus

If detection has a **deterrent effect**, it also contributes to preventing active attacks.

This comparison tells us how to respond to each family of attacks. For passive attacks: can we detect them? Very difficult. Can we prevent them? Yes, it is feasible. So our strategy is prevention, mainly through encryption. Why? Because no data is altered, so there is nothing to detect. For active attacks, it is the opposite. Detection is possible, but prevention is very difficult, because there are too many physical, software and network weaknesses to cover. So our strategy is detection and recovery. And notice the bonus point in green: if detection deters attackers, it also helps prevent attacks. Attackers think twice when they know they will be caught.

Slide 36 | The Six Security Services (about 45 seconds)

The Six Security Services



What is a security service?
A base-level service used to combat security attacks.

Do not confuse
Services are not mechanisms. Mechanisms are the actual implementations of these services.

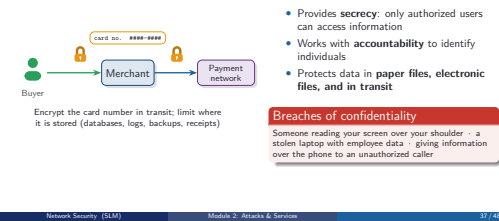
The next slides take each service in turn.

Now we come to the solution side: security services. Look at the circle. There are six security services: confidentiality, authentication, integrity, non-repudiation, access control and availability. A security service is a base-level service used to combat security attacks. Please be careful with one point that students often confuse in examinations, shown in the red box. Services are not the same as mechanisms. A service is what we want to achieve. A mechanism is the actual implementation, the tool that achieves it. For example, confidentiality is a service, and encryption is a mechanism that provides it. Let us take each service in turn.



Slide 37 | Service 1: Confidentiality (about 46 seconds)

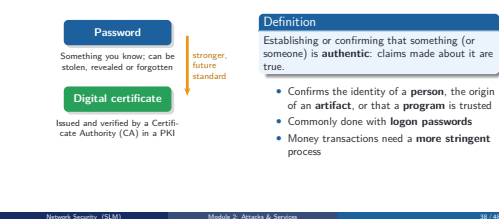
Service 1: Confidentiality



The confidentiality service provides secrecy of information: only authorized users can access it. To do this properly, it works together with an accountability service that identifies individuals. Confidentiality protects information in all its forms: paper files, electronic files and data in transit. Look at the diagram. When you buy something online, your card number travels from you to the merchant and then to the payment network. The system enforces confidentiality by encrypting the card number in transit and limiting where it is stored. The red box lists simple breaches: someone reading your screen over your shoulder, a stolen laptop, or careless phone calls.

Slide 38 | Service 2: Authentication (about 47 seconds)

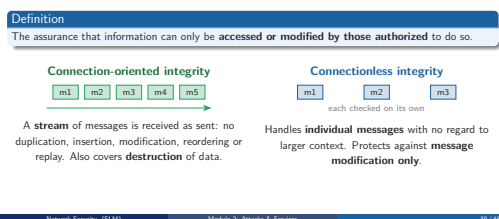
Service 2: Authentication



Authentication is the act of establishing or confirming that something, or someone, is authentic, meaning that claims made about it are true. It might confirm the identity of a person, the origin of an artifact, or that a program is trusted. In computer networks, authentication is commonly done with login passwords. But look at the left side of the slide. Passwords have a weakness: they can be stolen, accidentally revealed or simply forgotten. So for important transactions, such as exchanging money, a stronger process is needed. Digital certificates, issued and verified by a Certificate Authority as part of a public key infrastructure, are becoming the standard.

Slide 39 | Service 3: Integrity (about 46 seconds)

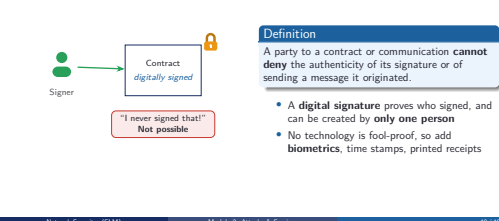
Service 3: Integrity



Integrity is the assurance that information can only be accessed or modified by those authorized to do so. There are two kinds. On the left is connection-oriented integrity. It deals with a stream of messages, shown as m1 to m5, and assures they are received exactly as sent, with no duplication, insertion, modification, reordering or replay. It also covers destruction of data, so it addresses both modification and denial of service. On the right is connectionless integrity. It deals with individual messages, each checked on its own, without any larger context, and protects against message modification only. So connection-oriented integrity gives broader protection.

Slide 40 | Service 4: Non-Repudiation (about 45 seconds)

Service 4: Non-Repudiation



Non-repudiation is the ability to ensure that a party to a contract or communication cannot deny the authenticity of their signature, or deny sending a message they originated. To repudiate means to deny. Look at the diagram. A signer digitally signs a contract. Later, if they say, I never signed that, it is not possible, because a digital signature can be created by only one person. However, no security technology is absolutely fool-proof. So some experts suggest combining several approaches, such as capturing biometric information, time stamps and printed receipts, which together make it very difficult for the signer to deny anything.

**Slide 41 | Services 5 & 6: Access Control and Availability (about 45 seconds)****Services 5 & 6: Access Control and Availability****Access control**

The ability to **permit** or **deny** the use of a resource by a particular entity.

- Physical** Movie theatre: ticket holders only
- Logical** Bank account: limited people may withdraw
- Digital** Private file: only some users may read

Availability

A system or resource is **accessible and usable on demand** by an authorized entity, per its specifications.

- Network, hardware and software are **reliable**
- They **recover quickly** after an interruption
- They should resist **denial-of-service** attacks

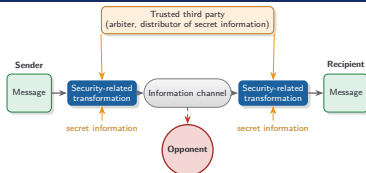
Access control is the ability to permit or deny the use of a resource by a particular entity. Look at the three examples on the left. A physical resource, like a movie theatre, admits only ticket holders. A logical resource, like a bank account, allows only a limited number of people to withdraw money. A digital resource, like a private document, can be read only by certain users. On the right is availability: a system is available if it is accessible and usable on demand by authorized users. This means reliable hardware and software that recover quickly and resist denial of service.

Slide 42 | Which Service Fights Which Attack? (about 46 seconds)**Which Service Fights Which Attack?**

	Confid.	Auth.	Integrity	Non-rep.	Access	Avail.
Release of contents	✓					✓
Traffic analysis	✓					
Masquerade		✓			✓	
Replay		✓	✓			
Modification			✓	✓		
Denial of service						✓

Every attack is answered by at least one service, and each service is built from mechanisms (Modules 6–12).

This table connects the two halves of today's class: attacks and services. Read it row by row. Release of message contents is countered by confidentiality and access control. Traffic analysis is countered by confidentiality. Masquerade is countered by authentication and access control. Replay is countered by authentication and integrity. Modification is countered by integrity and non-repudiation. And denial of service is countered by availability. Notice, as the bottom box says, that every attack is answered by at least one service. And each of these services is built from mechanisms that we will study in Modules 6 to 12. This table is worth memorising.

Slide 43 | A Model for Network Security (about 45 seconds)**A Model for Network Security**

- Two **principals** cooperate over a logical channel (a route through the Internet using protocols such as TCP/IP)
- Security = a **transformation** of the message (e.g. encryption) + **secret information** shared by the two (e.g. a key)

Here is a general model for network security from your study material. A sender wants to send a message to a recipient across the Internet. First, the message passes through a security-related transformation, such as encryption. Both sides also use secret information, such as a key, unknown to the opponent. The message then travels over the information channel, where an opponent may try to attack it. At the other end, the reverse transformation recovers the message. At the top, a trusted third party may be needed, for example to distribute the secret information or to settle disputes between the two principals.

Slide 44 | Four Basic Tasks in Designing a Security Service (about 46 seconds)**Four Basic Tasks in Designing a Security Service**

- 1 Design an **algorithm** for the security-related transformation that an opponent cannot defeat
- 2 Generate the **secret information** to be used with the algorithm
- 3 Develop methods to **distribute and share** the secret information
- 4 Specify a **protocol** that uses the algorithm and secret information to achieve the service

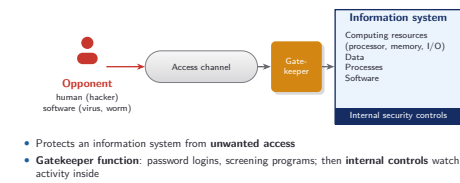
A **trusted third party** may distribute the secret information or settle disputes between the principals.

This model shows that there are four basic tasks when designing any security service. Task one: design an algorithm for the security-related transformation, strong enough that an opponent cannot defeat its purpose. Task two: generate the secret information, such as keys, to be used with that algorithm. Task three: develop methods for distributing and sharing this secret information safely. Task four: specify a protocol that the two principals will follow, using the algorithm and the secret information, to achieve the security service. These four tasks are a frequent examination question, so please learn them in this exact order. Think: algorithm, secret, sharing, protocol.



Slide 45 | The Network Access Security Model (about 46 seconds)

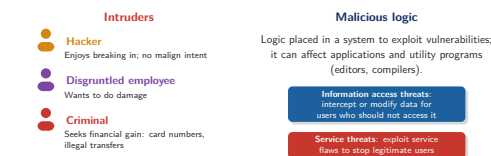
The Network Access Security Model



This second model protects an information system from unwanted access. On the left is the opponent, who could be a human, such as a hacker, or software, such as a virus or worm. The opponent comes through the access channel. Before reaching the system, they meet the gatekeeper function, shown in orange. This includes password-based logins and screening programs that block unwanted access. Inside the information system are its valuable resources: computing resources, data, processes and software. And even if something gets past the gatekeeper, internal security controls continue to monitor activity and detect unwanted intruders. Security does not stop at the front door.

Slide 46 | Who Are the Intruders? What Do They Threaten? (about 45 seconds)

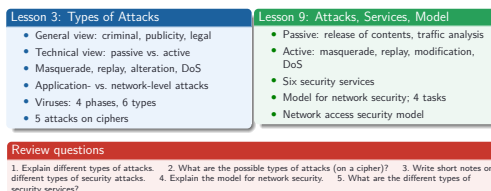
Who Are the Intruders? What Do They Threaten?



Who are these intruders? On the left are three types. A hacker may have no malign intent and simply enjoys breaking into systems. A disgruntled employee wants to do damage. A criminal seeks financial gain, for example by stealing credit card numbers or making illegal money transfers. On the right is another kind of unwanted access: malicious logic placed in a system to exploit vulnerabilities, affecting applications and even utilities such as editors and compilers. Such programs present two kinds of threats. Information access threats intercept or modify data. Service threats exploit service flaws to stop legitimate users from working normally.

Slide 47 | Module 2 Summary (about 47 seconds)

Module 2 Summary



Let us summarise. From Lesson 3, we learned the general view of attacks, criminal, publicity and legal, and the technical view, passive and active. We studied masquerade, replay, alteration and denial of service, application-level and network-level attacks, the four phases and six types of viruses, and the five attacks on ciphers. From Lesson 9, we learned the standard passive and active attacks, the six security services, the model for network security with its four tasks, and the network access security model. Please answer the five review questions in red before our next class; they are very likely examination questions. Write full answers, not just one line.

Slide 48 | References (about 46 seconds)

References

1. William Stallings, *Cryptography and Network Security*, PHI Publishers.
2. Charlie Kaufman, Radia Perlman, *Network Security*, Pearson Education.
3. Bruce Schneier, *Applied Cryptography*, John Wiley & Sons.
4. Roberta Bragg, *Network Security: The Complete Reference*, TMH.

Thank You! Questions?

Here are the reference books for this module. The first is Cryptography and Network Security by William Stallings, our main textbook; the model for network security we studied today comes straight from it. The second is Network Security by Kaufman and Perlman. The third is Applied Cryptography by Bruce Schneier, which is great for deeper reading on attacks against ciphers. The fourth is Network Security: The Complete Reference by Roberta Bragg. Please read the chapter on security attacks and services in Stallings before our next class. Thank you all for your attention today. Now, are there any questions? Please feel free to ask.